

CUMPLIMIENTO DE CONTROLES

ISO 27001

Año: 2026

Índice

1. A.5 — Controles organizacionales
2. A.6 — Controles de personas
3. A.7 — Controles físicos
4. A.8 — Controles tecnológicos

En base a los controles de la norma ISO/IEC 27001 (obtenidos de internet), se indica a continuación cuáles aplican a Ascentio Technologies, con su respectiva justificación.

1. A.5 — Controles organizacionales

Control	Descripción	Aplica	Justificación
A.5.1	Políticas de seguridad de la información	Aplica	Si no existen, se deben formalizar políticas de seguridad de la información.
A.5.2	Roles y responsabilidades de seguridad	Aplica	Si no están definidos, se deben definir responsables de cada sistema.
A.5.3	Segregación de funciones	Aplica	Evitar que un único usuario administre todos los sistemas críticos.
A.5.4	Responsabilidades de la dirección	Aplica	La dirección debe comprometerse formalmente con el SGSI.
A.5.5	Contacto con autoridades	Aplica	Ante incidentes, se deben contactar las autoridades competentes.
A.5.6	Contacto con grupos de interés especial	Aplica	Estar actualizado respecto a nuevos CVEs.
A.5.7	Inteligencia de amenazas	Aplica	Monitoreo de amenazas.
A.5.8	Seguridad de la información en gestión de proyectos	Aplica	Incorporar seguridad en el ciclo de desarrollo de software.
A.5.10	Uso aceptable de activos	Aplica	Definir políticas de uso aceptable para los servicios.
A.5.11	Devolución de activos	Aplica	Si no existe, se deberá definir un procedimiento formal para la devolución de activos al terminar la relación laboral.
A.5.14	Transferencia de información	Aplica	El uso de FTP incumple directamente este control.
A.5.15	Control de acceso	Aplica	Varios servicios están expuestos sin control de acceso adecuado.
A.5.16	Gestión de identidades	Aplica	Analizar la gestión de usuarios en todos los sistemas.
A.5.17	Información de autenticación	Aplica	Establecer políticas formales de contraseñas y gestión de credenciales.

Control	Descripción	Aplica	Justificación
A.5.21	Gestión de seguridad en cadena de suministro TIC	Aplica	Software con librerías desactualizadas.
A.5.24	Planificación de gestión de incidentes	Aplica	Si no existe, se deberá definir un plan formal de respuesta a incidentes.
A.5.25	Evaluación de eventos de seguridad	Aplica	Clasificar y evaluar eventos de seguridad detectados.
A.5.26	Respuesta a incidentes de seguridad	Aplica	Si no existe, se deberá definir procedimiento de respuesta ante intrusiones detectadas.
A.5.27	Aprendizaje de incidentes de seguridad	Aplica	Incorporar lecciones aprendidas de cada incidente ocurrido.
A.5.28	Recolección de evidencias	Aplica	Preservar y gestionar logs.
A.5.29	Seguridad de la información durante interrupción	Aplica	Garantizar la continuidad de la seguridad ante interrupciones.
A.5.30	Preparación TIC para continuidad del negocio	Aplica	Si no existe, se deberá definir un plan de contingencia para los sistemas críticos.
A.5.31	Requisitos legales, estatutarios y contractuales	Aplica	Cumplimiento de regulaciones de protección de datos.
A.5.32	Derechos de propiedad intelectual	Aplica	Gestión de licencias de software open source utilizado.
A.5.33	Protección de registros	Aplica	Protección e integridad de logs de todos los sistemas.
A.5.34	Privacidad y protección de datos personales	Aplica	Datos de clientes y partners almacenados en sistemas seguros e identificados.
A.5.35	Revisión independiente de seguridad	Aplica	Realizar auditorías externas periódicas.
A.5.36	Cumplimiento de políticas de seguridad	Aplica	Verificar el cumplimiento interno de las políticas definidas.
A.5.37	Procedimientos operativos documentados	Aplica	Documentar procedimientos de administración y gestión de todos los sistemas.

Cuadro 1: Controles ISO 27001 - A.5 Organizacionales

2. A.6 — Controles de personas

Control	Descripción	Aplica	Justificación
A.6.1	Investigación de antecedentes	Aplica	Verificación de antecedentes de las personas con acceso a sistemas críticos.
A.6.2	Términos y condiciones de empleo	Aplica	Incluir cláusulas de confidencialidad y seguridad en los contratos laborales.
A.6.3	Concienciación, educación y formación en seguridad	Aplica	Capacitar al personal sobre phishing, ingeniería social y buenas prácticas de seguridad.
A.6.4	Proceso disciplinario	Aplica	Definir sanciones formales ante incumplimiento de las políticas de seguridad.
A.6.5	Responsabilidades tras el cese o cambio de empleo	Aplica	Revocar los accesos a todos los sistemas al desvincularse un empleado.
A.6.6	Acuerdos de confidencialidad	Aplica	NDAs con empleados, contratistas, clientes, proveedores y partners.
A.6.7	Trabajo remoto	Aplica	Si no existen, definir políticas de acceso seguro desde fuera de las oficinas de la empresa.
A.6.8	Reporte de eventos de seguridad	Aplica	Establecer un canal formal para reportar incidentes internamente.

Cuadro 2: Controles ISO 27001 - A.6 Personas

3. A.7 — Controles físicos

Control	Descripción	Aplica	Justificación
A.7.1	Perímetros de seguridad física	Aplica	Protección física a los oficinas.
A.7.2	Entrada física	Aplica	Control de acceso físico a la sala de servidores.
A.7.3	Seguridad de oficinas y salas	Aplica	Protección de áreas con equipos críticos de la organización.
A.7.4	Monitoreo de seguridad física	Aplica	Implementar CCTV y sistemas de alarma en oficinas.
A.7.5	Protección contra amenazas físicas y ambientales	Aplica	Protección ante incendios y otras amenazas ambientales.
A.7.6	Trabajo en áreas seguras	Aplica	Si no existen, definir un procedimiento para el trabajo en zonas de acceso restringido.
A.7.8	Ubicación y protección de equipos	Aplica	Protección física adecuada de servidores y equipos de red.
A.7.9	Seguridad de activos fuera de las instalaciones	Aplica	Gestión segura de dispositivos móviles de empleados fuera de la oficina.
A.7.10	Medios de almacenamiento	Aplica	Gestión segura de discos, USB y otros medios extraíbles.
A.7.11	Servicios de suministro	Aplica	Disponer de UPS y redundancia eléctrica para garantizar disponibilidad de servidores.
A.7.12	Seguridad del cableado	Aplica	Protección del cableado de red contra interferencias y accesos no autorizados.
A.7.13	Mantenimiento de equipos	Aplica	Realizar mantenimiento preventivo y correctivo de servidores y equipos.
A.7.14	Eliminación segura o reutilización de equipos	Aplica	Borrado seguro de datos al retirar o reutilizar equipos de la organización.

Cuadro 3: Controles ISO 27001 - A.7 Físicos

4. A.8 — Controles tecnológicos

Control	Descripción	Aplica	Justificación
A.8.1	Dispositivos de usuario final	Aplica	Gestión segura de dispositivos móviles y laptops de empleados.
A.8.2	Derechos de acceso privilegiado	Aplica	Control estricto de accesos admin en todos los sistemas y equipos.
A.8.3	Restricción de acceso a la información	Aplica	Los sistemas deben restringir el acceso según los roles definidos.
A.8.5	Autenticación segura	Aplica	Si no se utiliza, se deberá implementar el acceso con MFA en todos los servicios, especialmente los expuestos a internet.
A.8.6	Gestión de capacidad	Aplica	Planificación y gestión adecuada de recursos de los servidores en producción.
A.8.7	Protección contra malware	Aplica	Implementar antimalware en todos los servidores identificados.
A.8.8	Gestión de vulnerabilidades técnicas	Aplica	Las versiones desactualizadas de Nginx 1.10.3, Apache 2.4.29 y OpenSSH 7.6p1 incumplen directamente este control.
A.8.9	Gestión de la configuración	Aplica	Las configuraciones inseguras detectadas incumplen este control.
A.8.10	Eliminación de información	Aplica	Borrado seguro de información sensible cuando ya no es necesaria.
A.8.11	Enmascaramiento de datos	Aplica	Proteger datos sensibles almacenados en bases de datos MySQL.
A.8.12	Prevención de fuga de datos	Aplica	IP privada y servicios internos expuestos públicamente.
A.8.13	Copias de seguridad	Aplica	Si no se realiza, se deberán realizar backups regular de los servicios críticos.
A.8.14	Redundancia de instalaciones de procesamiento	Aplica	Tener alta disponibilidad en los servicios críticos.

Control	Descripción	Aplica	Justificación
A.8.15	Registro de actividad	Aplica	Logs de acceso a todos los servicios expuestos, sobre todo en los expuestos a internet.
A.8.16	Actividades de monitoreo	Aplica	Monitoreo continuo de los servicios.
A.8.17	Sincronización de relojes	Aplica	Utilizar NTP para el sincronizado de la hora y fecha en todos los servidores.
A.8.18	Uso de programas utilitarios privilegiados	Aplica	Realizar un control y auditoría de las herramientas de administración y gestión de los sistemas.
A.8.19	Instalación de software en sistemas operativos	Aplica	Contar con una política formal de instalación de software en los servidores productivos.
A.8.20	Seguridad en redes	Aplica	Contar con una segmentación de red apropiada y que siga las buenas prácticas.
A.8.21	Seguridad de servicios de red	Aplica	Utilizar protocolos seguros para la administración de los equipos y sistemas.
A.8.23	Filtrado web	Aplica	Tener control del tráfico saliente desde los servidores de producción.
A.8.24	Uso de criptografía	Aplica	Implementar cifrado en todos los sistemas.
A.8.26	Requisitos de seguridad de aplicaciones	Aplica	Definir requisitos de seguridad para las aplicaciones desarrolladas.
A.8.28	Codificación segura	Aplica	Implementar buenas prácticas de codificación segura en el equipo de desarrollo.
A.8.29	Pruebas de seguridad en desarrollo y aceptación	Aplica	Realizar tests de seguridad obligatorios antes de pasar a producción.
A.8.32	Gestión de cambios	Aplica	Contar con un proceso formal requerido para cambios en sistemas de producción.
A.8.33	Información de prueba	Aplica	Prohibir el uso de datos reales en entornos de prueba y desarrollo.
A.8.34	Protección de sistemas durante auditoría	Aplica	Proteger los sistemas de información durante el proceso de auditoría.

Cuadro 4: Controles ISO 27001 - A.8 Tecnológicos